Subsidiary pack: MERIDIAN Logistique

Module M2-01-4-ISMS, Security Governance and Information System Mapping. Session 2. Reviewed by groups G3 (translog-a) and G4 (translog-b). Version 1, 3 September 2026.

> *Fictional company. The people, contracts, incidents, equipment and figures in this pack were built for the purposes of the module and have no real existence.*

1. What this pack is, and from which chair it is read

The working group plays the part of the **Group CISO of MERIDIAN**, as the reference pack set it out in session 1: appointed six weeks ago, reporting to Executive Management, with no predecessor, no PSSI and no consolidated budget. The Group CISO sets the common framework, arbitrates what the subsidiaries cannot arbitrate alone, answers to Executive Management for the security of the group, and administers no system. The Group CISO does not replace the Logistique subsidiary's IT manager.

This pack is what sits on the Group CISO's desk about MERIDIAN Logistique, the subsidiary under review today: what the subsidiary sent when the Group CISO asked for its inventory, what the initial diagnostic found there, what crosses its boundary towards the rest of the group, and who decides what within it. Reviewing a subsidiary means drawing its map within the group's reference framework, with the group's vocabulary, and drawing out of it what the group needs to know about it. What gets written commits the group, not the subsidiary.

Two groups review the same subsidiary without consulting each other and compare their results in plenary. Each group works in its own instance of the governance tool.

What this pack does not contain. No business asset, no supporting asset, no security need rating. The elements are cited as the subsidiary names them or as the diagnostic encountered them, without qualification. Classifying them, linking them and rating them is the working group's task. The reference pack remains the group's context; for this session, the work is done from the present pack.

2. The subsidiary

MERIDIAN Logistique, 2,800 employees, operates six automated warehouses and provides transport and warehousing under controlled temperature. Four warehouses are equipped with sorting machines; two, smaller, run manually with handheld scanners. Two warehouses, including the largest, are dedicated to a pharmaceutical customer whose contract provides for penalties of €12,000 per day of stoppage and annual cold chain audits.

The WMS (warehouse management system) drives order picking, shipping and stock across the six sites. It is maintained by a third-party application maintenance (TPAM) provider. The sorting machines are installed and maintained by an integrator, which accesses them through a 4G box placed outside the supervised network; its contract contains neither a reversibility clause nor any security requirement. A fleet of vehicles fitted with telematics provides transport between the warehouses and to customers; the trailers' temperature data is recorded there.

At the first interview, the Managing Director of the subsidiary summed up the subsidiary's concerns in three points: continuity of shipping, the cold chain and the pharmaceutical customer's contractual penalties. A stoppage of more than six hours blocks 40% of the group's shipped volume. In April, a WMS stoppage lasted part of the day: everyone called whoever they could, and nobody kept a timeline.

3. The map of power

Who decides what at MERIDIAN Logistique, and what each of them has let be known. The positions below were stated to the Group CISO during the first interviews; they are neither instructions nor solutions, they are the terrain.

FUNCTION	DECIDES ON	DOES NOT DECIDE ON	STATED POSITION
Managing Director of the subsidiary	Budget, contracts (TPAM provider, integrator, pharmaceutical customer, transport), opening or closing a warehouse	Rules common to the group; what Santé agrees to receive	"€12,000 a day is the only figure I look at." Wants no intervention on the automated systems during peak periods, that is ten months out of twelve.
Operations Manager (the six warehouse managers report to the Operations Manager)	Organisation of the warehouses, picking procedures, the industrial network of the automated systems, calling in the integrator	The WMS, which falls under the TPAM provider; the office network and accounts, which fall under the IT manager	"I know everything by heart, just ask me, no need for an inventory." Had the integrator's 4G box installed "so as not to depend on IT any more when a machine goes down".
The subsidiary's IT manager (does not carry the CISO title, three people)	Office network, workstations, domain accounts, relationship with the WMS TPAM provider	Industrial network and automated systems; telematics; contracts	"The WMS is the TPAM provider's business; the automated systems are Operations' business; I keep the workstations and the network running." Sent no inventory: "there is none, everything is in the WMS". Does not know how many people use the TPAM provider's domain account.
Warehouse managers (six)	Staff, schedules, shipping priorities of their site	Nothing technical	Each has the mobile number of an integrator technician and calls that technician directly. During the April stoppage, three of them called the TPAM provider, two the integrator, one the IT manager.
Transport Manager	Fleet, telematics contract, route scheduling	Warehouses, WMS	"Telematics is a subscription, the supplier handles everything, we look at a screen."
Quality and Cold Chain Manager	Temperature probes, alert thresholds, responses to the pharmaceutical customer's audits	Tools and network	Dreads the customer's next visit: "they will ask who has access to the temperature readings and I will not be able to answer".
WMS TPAM provider	Its interventions on the WMS, its updates	The security of the subsidiary's information system	Intervenes with a shared domain account, whose number of users is not known. The contract provides for on-call duty, not for logging by named user.

Integrator for the automated systems	Its interventions on the automated systems, remotely through the 4G box or on site	The security of the subsidiary's information system	Contract with neither a reversibility clause nor any security requirement. Regards the settings of the automated systems as its industrial property.
Pharmaceutical customer	Its contractual requirements, its audits	Nothing in operations	Penalties of €12,000 per day of stoppage; annual cold chain audit; has announced a security questionnaire for the next audit.
Internal Audit of the holding company	The audit programme, requests for documents	Nothing in operations	Asked for the list of the TPAM provider's accounts; received one account name and no person's name.

What the subsidiary expects from the Group CISO: to stop nothing, and to settle with Santé the blocking of the replenishment flow, which Logistique experiences as an affront. What it fears: a common rule written for a hospital and applied to a warehouse.

4. The inventory as the subsidiary sent it

The subsidiary IT manager's reply to the Group CISO's request for an inventory: "there is no inventory, everything is in the WMS, and for the rest it is in the Operations Manager's head, he knows his six warehouses by heart". The Group CISO therefore spent a morning with the Operations Manager. Interview notes, reproduced as they were taken. The warehouses are noted E1 to E6.

- "Six warehouses. E1 is the largest and the oldest, that is where the WMS servers are, in a room at the back of the maintenance workshop, the air conditioning gave out twice this summer. E2 and E3 have sorting machines, E4 too since last year, E5 and E6 are manual with the handheld scanners. E1 and E4 are reserved for the pharma customer."
- "The WMS runs on two servers at E1 plus a database. The five other warehouses connect to it through the operator's links. If the link goes down, the warehouse stops picking, we saw that in April. The TPAM provider does the updates at night, whenever it wants, we find out in the morning."
- "The handheld scanners, there are three hundred and some, I can get you the exact number per warehouse. They talk to the WMS over Wi-Fi. The same scanners send the stock movements to Santé's pharmacy system, well, used to send them, they cut everything off three months ago, we deliver by hand on paper purchase orders."
- "The automated systems are the integrator's business. They are on the same network as the offices, nobody ever separated them, it works. The integrator connects through its 4G box, so when a machine is down it does not go through IT. The account linking the WMS to the automated systems is the same everywhere since 2019, the password is in the config file, everyone in Operations knows it."
- "The WMS backups run every night, the TPAM provider confirmed it to me. Restore? Never needed to."

- "The cold chain is the probes in the cold rooms and in the trailers. The readings go up to a piece of software from the probe supplier, hosted at their end, Quality has access to it, and the pharma customer gets a monthly report. The trailers are telematics, another supplier, another screen."
- "The pharma customer has a portal where we enter the shipments, with one account per warehouse."
- "In April, the WMS stopped around 10 am. E3 called the TPAM provider, E1 called the integrator, who said it was not them, E4 called the IT manager, who was on leave. It started again in the early afternoon, we never found out why. The pharma customer was notified by the E1 manager, by phone, on their own initiative."
- "The office computers and the accounts are the IT manager's business. Payroll and accounting are an online application, the holding company's CFO has control of it."
- "An inventory, honestly, I can do it for you from memory."

What the Group CISO knows besides, and which does not appear in these notes: the WMS TPAM provider intervenes with a shared domain account that nobody knows how many people hold; the group SOC receives the logs of Logistique's office network, not those of the automated systems or the 4G box; the holding company's Chief Financial Officer (CFO) keeps the subsidiary's payroll and accounting on an online application shared across the group.

5. The diagnostic findings that concern the subsidiary

Noted during the initial diagnostic, reproduced as is.

1. The **office and industrial networks are interconnected**, without segmentation.
2. A **domain account is shared with the third-party maintenance provider**, used by a number of people nobody can establish.
3. The service account linking the WMS to the automated systems has carried **the same password across all six warehouses since 2019**, in clear text in a configuration file.
4. The WMS backups run every day and **have never been restored** since commissioning.
5. A stoppage of more than six hours blocks **40% of the group's shipped volume**.
6. There is **no incident procedure**: during the April stoppage, everyone called whoever they could.

One contractual fact is added to these: the integrator for the automated systems connects through a 4G box outside the supervised network, under a contract with neither a reversibility clause nor any security requirement.

6. What crosses the subsidiary's boundary

- **Towards Santé.** The warehouse handheld scanners used to feed MERIDIAN Santé's pharmaceutical stock management system, through a replenishment API on a dedicated VLAN with an inspection firewall, the only network segmentation the diagnostic found in the group. The flow has been blocked for three months at the request of the Santé subsidiary CISO: "their equipment cannot be trusted". Logistique delivers to the pharmacy on paper purchase orders in the meantime. On the Santé side, these stock movements fed the orders of the hospital pharmacy, including the emergency replenishment of the facilities; Santé's Chief Pharmacist has let the Group CISO know that the flow should resume: "we are managing with manual orders, it will not last the winter".
- **Towards the group SOC.** The centralised SOC, still ramping up, receives the logs of Logistique's office network; it receives nothing from the automated systems, the 4G box or the WMS itself.
- **Towards the holding company.** Internal Audit is waiting for the named list of users of the TPAM provider's account. The CFO keeps the subsidiary's payroll and accounting.
- **Towards the outside.** The WMS TPAM provider; the integrator for the automated systems; the temperature probe supplier and its hosted software; the telematics supplier; the operator of the links between warehouses; the pharmaceutical customer and its shipping portal.

7. What Executive Management expects

A security governance common to the four subsidiaries, without stopping production, without new budget in the first year, presentable to the Board of Directors. "I do not want a report, I want to know who decides what." For Logistique, Executive Management added a question, put after the April stoppage: "if it stops for six hours, who calls whom, and who decides to notify the customer?"